

MSME AI DPR Generation Tool

Project, architecture, roles, deployment, and testing documentation

Product	AI-enabled Detailed Project Report (DPR) platform for MSME entrepreneurs and consultants, with Andhra Pradesh scheme matching
Repository	AI_DRP
Branch	feature/live_cust
Commit documented	b9be78a (8 October 2026). Working tree matched this commit when the document was written.
Document date	8 October 2026
Audience	Incoming engineering, operations, and product owners
Source of facts	Application code, tests, and docs in this repository. Claims that exist only in the root README and are not implemented are called out as such.

This document describes what the code does today. It is not a legal opinion, a DPDP compliance certificate, or an infrastructure runbook for a host that has not been chosen yet.

How to read this document

Each section follows the handover outline. Where a topic is only partly built, the text says what is in the code and what is still open. Hosting and infrastructure ownership are recorded only where the repository already names a target. A full infrastructure design is deferred until the receiving organisation states its own requirements.

Living product docs already in the repo (keep these updated when behaviour changes): docs/dpdp.md, docs/create-new-dpr-business-logic.md, docs/venture-match-business-logic.md, docs/schemes/*, llm.md, styleeditor.md.

Contents

1. Project documentation
2. Architecture documentation
3. User roles and permissions
4. Deployment and handover
5. Testing and QA

1. Project documentation

1.1 Project overview

The product is a bilingual (English and Telugu) web application that helps a consultant or entrepreneur produce a bank-ready Detailed Project Report. Users can match government and Andhra Pradesh MSME schemes, fill a scheme-specific form with optional AI assistance, preview a styled document, and download PDF, DOCX, or XLS.

The workspace is a two-package repository:

- `client/` — React 18 + TypeScript single-page app (Vite). Package name `msme-dpr-client`, version 1.0.0.
- `server/` — Node.js + Express + TypeScript API. Package name `msme-dpr-server`, version 1.0.0. MongoDB via Mongoose.

Primary user journeys on this branch:

- **Scheme Finder** (`/venture-match`) ranks schemes with deterministic client-side rules, then hands the chosen scheme into a DPR.
- **Create New Latest DPR** (`/individual-dpr/create`) builds a single-unit report. Each scheme has its own step list. A blank scheme is a vanilla bank term-loan pack of 18 steps.
- **Cluster DPR** (`/cluster-dpr/create`) builds a multi-unit / SPV cluster report with generated narrative sections.
- **AI Guided Builder** (`/dpr/builder`) and **Chat** (`/chat`) are separate assisted paths. Scheme Finder can also hand off into the guided builder.
- **Style and preview** edits page size, type, colours, section order, and pictures for one DPR. The downloaded PDF is the document on screen.
- **Privacy account** (`/account/privacy`) covers notice consent, AI on/off, data export, nominee, complaint, and account erasure.
- **Admin console** (`/admin`, `/admin/documents`) covers analytics, users, DPR review, policies, audit, and RAG document upload.

1.2 Project objectives and scope

In scope on this branch

- Account registration and login for adults (18+), with a privacy notice that must be scrolled and accepted.
- Scheme eligibility matching for the catalog in `client/src/lib/ventureMatch/schemes.ts` (about 38 scheme codes, including PMEGP, MUDRA, CGTMSE, AP CMEP, PMEGP 2nd loan, short packs such as ZED and LEAN, and cluster routes such as MSE-CDP and SFURTI).
- Draft, generate, preview, style, and download individual and cluster DPRs.
- Optional AI fill, chat, translation to Telugu, quality scoring, and image generation, all gated by AI consent. Identity numbers are stripped before model calls.
- English and Telugu interface copy (`client/src/i18n/locales/en.json` and `te.json`).
- Admin review of users, DPRs, policies, and an append-only audit log.
- In-app retention warnings and a purge job for idle DPRs and old audit rows.

Out of scope or not finished

- A native mobile app, blockchain verification, and an API marketplace (listed as future ideas in the root README only).
- Live, contracted integration with the AP MSME ONE portal. The client calls a configurable URL and falls back to mock scheme data when that call fails. Submission throws if the remote call fails.
- Real email delivery. Outbound mail is a server log line. SMS is real only when Twilio environment variables are set.
- DPDP Stage 4 (named grievance officer, real inbox, vendor contracts, breach playbook). Stages 1–3 are in code. `docs/dpdp.md` states this is not a compliance certificate.
- Hosting design for the receiving organisation. See Part 4.

1.3 Features and modules

Module	Where it lives	What it does
Landing, login, register	pages/Landing.tsx, Login.tsx, Register.tsx	Public entry. Register collects name, email, password (min 6), 10-digit phone, date of birth, and privacy consent. Under 18 is refused.
Dashboard and project list	Dashboard.tsx, Projects.tsx, AllDPRs.tsx	Own projects and DPRs. Dashboard shows the latest five reports. Govt-official role does not see create actions.
Scheme Finder	pages/VentureMatch.tsx, lib/ventureMatch/	14 base questions plus conditional ones. Matching is on the client. Optional help chat. Results route to individual DPR, cluster DPR, or a CTA with no DPR.
Individual DPR	IndividualDPRCreation.tsx, components/individual-dpr/, lib/individualDpr/	Scheme step catalogs, live document, inline edit, style editor, scheme briefs, uploads. Persists through the cluster draft API with <code>isIndividualDPR: true</code> .
Cluster DPR	ClusterDPRCreation.tsx, components/cluster-dpr/	Cluster narrative, financial statements, section regenerate, images, annexures.
Guided builder and chat	AIGuidedDPRBuilder.tsx, Chat.tsx	Step analysis and chat. RAG can use uploaded admin documents.
Preview and export	DPRPreview.tsx, server PDF/DOCX/XLS services	HTML capture PDF (Puppeteer) and generated documents. Telugu translation route exists.
Admin	AdminDashboard.tsx, AdminDocuments.tsx	Analytics, users, access-control preview, DPR approve/reject, policies, audit CSV, retention run, document upload.
Privacy	Privacy.tsx, AccountPrivacy.tsx	Public notice and signed-in rights: export, consent, nominee, complaint, activity, notifications, delete account.
Theme and dev mode	themeStore, DevModeToggle	Theme applies globally. Dev mode is super-admin only on create-DPR pages and skips required-field checks. It resets when the page is left.

1.4 Technology stack

Layer	In this repository
UI	React 18, TypeScript 5.3, Vite 5, Tailwind CSS 3, Radix UI (accordion, dialog, dropdown, select, tabs), Zustand, React Router 6, i18next, Recharts, Axios, react-hot-toast, react-markdown, Lucide icons
Client document tools	html2canvas, jsPDF, pdfjs-dist
API	Express 4, Helmet, CORS, compression, express-rate-limit, express-validator, Morgan, Multer, JWT, bcryptjs
Data	MongoDB (Mongoose 8). Connection pool 1–10, 60s connect timeout, 5 retries. No Redis client is installed.
AI	OpenAI SDK 4 (chat, Assistants / vector stores, Whisper, DALL-E 3). Fill-this-step uses <code>gpt-4o-mini</code> (llm.md). Telugu speech uses Hugging Face <code>vasista22/whisper-telugu-base</code> when configured, otherwise Whisper.
Documents	Puppeteer (HTML PDF), pdfkit, pdfmake, pdf-lib fontkit, docx. Local fonts under <code>server/fonts/</code> .
Other services in dependencies	Cloudinary (non-KYC media). Twilio is called with <code>fetch</code> when keys exist; the Twilio SDK is not a dependency. <code>@google/generative-ai</code> and <code>@xenova/transformers</code> are dependencies; image generation in <code>GeminiService</code> actually calls <code>OpenAI dall-e-3</code> .
Tests	Node test runner on client and server. Playwright for one browser flow. No Docker Compose file is in the repo.

The root README also names Redis, a CDN, and Docker Compose. Those are not present in `package.json` or the repository layout. Do not plan operations around them until they are added.

1.5 Frontend and backend overview

Frontend. `client/src/main.tsx` mounts `App.tsx`. Routes are listed in Part 2. State is Zustand (auth, individual DPR, theme, dev mode) plus local storage for the auth persist key, Scheme Finder progress (`venture-match-progress`), and Scheme Finder

handoff (venture-match-handoff). API access is `client/src/lib/api.ts`. Base URL is `VITE_API_URL` or `http://localhost:5000/api`. A short-lived in-memory cache (2–10 minutes) covers projects, DPRs, schemes, and profile. `VITE_USE MOCK_DATA=true` switches the client to `MockDataService`. The consent gate loads the live profile and does not use that mock path.

Backend. `server/src/index.ts` is the long-running process used in development and the process that runs the retention timer. It requires `OPENAI_API_KEY` at boot. In production it also requires a strong `JWT_SECRET` and `KYC_ENCRYPTION_KEY`. `server/api/index.ts` is a second Express entry (serverless-style). It mounts the same routes but uses a default CORS origin of `*`, a 10 MB JSON limit instead of 50 MB, and it does not run the production secret checks, scheme seed, RBAC seed, assistant pre-warm, or retention interval. Prefer `src/index.ts` unless a host is explicitly wired to the serverless file.

1.6 Business logic and key workflows

Scheme Finder

Questions and option ids are fixed in `lib/ventureMatch/questions.ts`. `evaluate()` returns matches and exclusions. Each match has a `dprRoute`: `full`, `short`, `cluster`, `cta`, or `none`. Full and short routes open `/individual-dpr/create?new=true&scheme=CODE`. Cluster opens `/cluster-dpr/create`. CTA matches do not create a DPR. The individual form does not copy Scheme Finder answers into fields. It stores them for overlay rules (uploads, MUDRA bands, PMEGP education, and similar). Full rules: `docs/venture-match-business-logic.md`.

Individual DPR

Step counts come from `schemeStepCatalog.ts`. Vanilla is 18 steps. PMEGP is 14. MUDRA is 12. Short packs are shorter. Generate is allowed on the last visible step and stores scheme answers. Preview and PDF use one section per catalog step (question and answer), not the cluster chapter set. Quality scoring reads those stored answers. A super admin can save a scheme’s style as the default for the next DPR. Existing DPRs keep their own style. Full rules: `docs/create-new-dpr-business-logic.md` and `styleeditor.md`.

Fill this step (AI)

Documented in `llm.md`. Empty questions on the current step are batched: one model call for short and structured fields, and a second call only if the step has long write-ups. Earlier steps are reduced to a facts card (unit, district, location, products, rupee amounts in ₹ lakhs). The model must not invent a project cost. Each value is checked in code (numbers, dates 1990–2100, list shape, cost ceiling of five times amounts already on the card, long answers of at least 40 words). One failed field is retried once. Cluster “Generate suggestions” is a separate path: one call for the whole cluster step, with previous cluster steps included. The OpenAI Batch API is not used, because the user is waiting.

Privacy and retention

Notice version is 2026–09–4. Account consent is required. AI assist and analytics are optional flags. Idle DPRs (draft or submitted) are warned 15 days before delete and removed 12 months after the DPR’s last edit. The user account is not deleted by that job. Audit rows are removed 24 months after they were written. Account erasure is a separate, explicit action and does not wipe audit rows.

1.7 Third-party integrations

Integration	Status in code
OpenAI	Required. Chat, DPR text, RAG / vector store, Whisper, DALL·E 3 images. All chat completions go through <code>server/src/lib/openaiClient.ts</code> , which runs <code>sanitizeForAi</code> .
Hugging Face Inference	Optional Telugu transcription. Needs <code>HUGGINGFACE_API_TOKEN</code> .
Cloudinary	Optional. Used for some media destroy/upload paths. KYC files and cluster unit photos are not sent to Cloudinary.
AP MSME ONE HTTP API	Optional. <code>AP_MSME_API_URL</code> (default <code>https://apmsme.ap.gov.in/api</code>) and <code>AP_MSME_API_KEY</code> . Scheme list falls back to in-code mock data on error. Submit and status throw on error. Scheme Finder itself does not call this API; it uses the in-repo catalog.
Twilio SMS	Optional. HTTP API, no SDK. Used by the retention warning.
MongoDB Atlas or any MongoDB 6+ URI	Required. <code>MONGODB_URI</code> .

1.8 Notification integrations

`NotifyService` (`server/src/services/notify.service.ts`) supports one kind today: `retention_warning`. It always writes an in-app `UserNotification`. The bell reads `GET /api/privacy/notifications` and mark-read `POST /api/privacy/notifications/:id/read` (`id` may be `all`).

- **SMS:** sent only when `TWILIO_ACCOUNT_SID`, `TWILIO_AUTH_TOKEN`, and `TWILIO_FROM` are all set and the user has a phone. Otherwise the server records a mock send. There is no Twilio SDK.
- **Email:** always mocked. The code comment marks SMTP as Stage 4. Privacy complaints are stored and a server log line is written. They are not emailed. Grievance address in the notice is `privacy.grievance@msmeone.gov.in` and is marked mock until Stage 4.

There is no push-notification provider, no WhatsApp integration, and no user-configurable notification preferences beyond the phone and email already on the account.

1.9 Analytics and tracking

There is no third-party product analytics SDK (no Google Analytics, Mixpanel, or similar) in the client dependencies.

Product analytics that do exist:

- **DPR quality record** (`DPRAnalytics` collection, `ml.service.ts`): quality, completeness, bankability, satisfaction, funding outcome, sector benchmark comparison. Admin `GET /api/admin/analytics` aggregates these.
- **RAG metrics** (`RAGMetrics` model) for document-assisted answers.
- **Audit events** for security-relevant actions (login, consent, DPR create/change/download/delete, KYC, export, admin view). These are an audit trail, not a marketing tracker. Rows do not store Aadhaar or DPR body text.
- **Client navigation memory** (`lib/navHistory`) so Back is named after the previous screen. It is local to the browser.
- **Consent flag privacy.analytics** is stored on the user. Unlike AI assist, it is not wired as a hard server gate on the analytics routes. Treat “analytics off” as stored preference until that gate is added.

AI token use for fill-this-step is written to the server process log as `llm.step` (step, short or long, field count, input and output tokens). Those lines are operator logs. They are not shown in the UI.

1.10 Known issues and limitations

1. **Registration accepts a role from the client.** `POST /api/auth/register` stores `role` when the body sends one, otherwise `entrepreneur`. The `User` enum allows `admin` and `officer`. The register screen sends the consultant mapping, but the API does not force that. A direct API call can request a privileged role. This should be fixed before a public production launch.
2. **Govt-official create restriction is a UI gate.** `canCreateDpr` hides create actions for `officer`. Project and DPR routes only require a valid JWT. An officer token can still call create and generate.
3. **Copy still says enforcement is UI-only.** English strings under `rbac` say “Enforcement is UI-only for now” and “Role updated in the UI”. Admin API routes do enforce the `admin` role. The strings overstate how open the API is, and understate the admin

- checks that already exist.
4. **Development accounts are seeded on boot** if missing (see Part 4). They must not remain in a shared or production database.
 5. **Two server entries behave differently** (`src/index.ts` vs `api/index.ts`). The serverless entry skips production secret checks and the retention job.
 6. **Email is not delivered**. Complaints and retention email are log-only.
 7. **AP MSME portal is not a reliable live integration**. Failures return mock schemes or an error. Scheme rules used by Scheme Finder are the in-repo catalog, which can drift from a future portal API.
 8. **README drift**. Redis, Docker Compose, CDN, and “GDPR compliance” are not implemented as stated. Privacy work follows the DPDP plan in `docs/dpdp.md`, and Stage 4 is still organisational.
 9. **/uploads is intentionally 404**. Files are served only through authenticated file routes. Anything that still expects a public upload URL will fail.
 0. **Large request bodies**. JSON limit is 50 MB on the main server so HTML+CSS can be posted for PDF capture. That is a denial-of-service consideration if the process is exposed without a gateway limit.
 1. **Dev mode** skips required fields for super admins. It is off by default and not persisted, but it must stay unavailable to other roles (it already checks `isSuperAdmin`).

1.11 Pending development and future enhancements

- Lock registration to entrepreneur unless an admin assigns another role. Enforce officer read/review rules on the API, not only in the UI.
- Align role labels: UI uses Super Admin / Consultant / Govt Official; database enum is `admin / entrepreneur / officer`.
- Real SMTP, a monitored grievance inbox, and Twilio (or an agreed SMS vendor) with keys outside the repo.
- DPDP Stage 4: legal name on paper, vendor contracts, breach playbook. Do not claim compliance before that.
- Decide whether `privacy.analytics` must block quality-score writes.
- Replace or confirm the AP MSME HTTP integration against a real portal contract. Until then, treat mock fallback as development behaviour.
- Remove boot-time RBAC seed from any shared environment.
- Choose one server endpoint and apply the same production guards to it.
- README items that are not scheduled in code: mobile apps, deeper ML models, blockchain, API marketplace. They are ideas only.
- Background work beyond the in-process retention timer (a real queue) is not built. Add one only if PDF generation or purge volume requires it.

2. Architecture documentation

2.1 Overall system architecture

Browser SPA → HTTPS JSON API → MongoDB. The API also calls OpenAI, and optionally Hugging Face, Cloudinary, Twilio, and the AP MSME HTTP API. PDF generation runs inside the API process (Puppeteer/Chrome). There is no separate worker service and no message broker.

Static frontend hosting in this repo is described by `vercel.json` (build `client`, SPA rewrite to `index.html`). The API is a separate Node process. Content-Security-Policy in the API allows framing from `localhost` and from `https://ai-dpr.up.railway.app`, and frame sources include `https://dpr-server.up.railway.app`. Those hostnames are the only production URLs named in code. They are not an infrastructure specification.

2.2 Frontend architecture

- **Routing:** React Router in `App.tsx`. Unknown paths redirect to `/`.
- **Auth gate:** `ProtectedRoute` checks a token in `Zustand` or `localStorage` (token and persisted `auth-storage`). Missing token goes to `/login`. `requiredRole` is compared with `toAppRole()`. A mismatch goes to `/dashboard`. Children sit inside `ConsentGate`, which blocks until the current privacy notice is accepted.
- **State:** `Zustand` stores. Server remains the source of truth for drafts after save.
- **i18n:** English and Telugu. `Scheme Finder` has no language toggle on its own page; the rest of the app follows the UI language.
- **UI kit:** Tailwind plus a small set of Radix primitives and shared layout (navbar, theme, accessibility bar, notification bell).

Path	Access
<code>/</code> , <code>/login</code> , <code>/register</code> , <code>/privacy</code>	Public
<code>/dashboard</code> , <code>/projects</code> , <code>/projects/create</code> , <code>/projects/:id</code>	Signed in
<code>/dpr/:projectId</code> , <code>/dpr/builder</code> , <code>/dpr/builder/:projectId</code> , <code>/dpr/view/:dprId</code> , <code>/dprs</code>	Signed in
<code>/individual-dpr/create</code> , <code>/cluster-dpr/create</code> , <code>/venture-match</code> , <code>/chat</code>	Signed in
<code>/profile</code> , <code>/account/privacy</code>	Signed in
<code>/admin</code> , <code>/admin/documents</code>	UI role Super Admin (backend admin)

`DPRAnalytics.tsx` exists under `pages` but is not registered in `App.tsx`. Admin analytics are on the admin dashboard instead.

2.3 Backend architecture

Express application, routes mounted at `/api` from `server/src/routes/index.ts`. Layers:

- **Routes** — `auth`, `projects`, `dpr`, `schemes`, `feedback`, `admin`, `ai`, `apmsme`, `documents`, `privacy`, plus `GET /api/health`.
- **Middleware** — `JWT authenticate`, `role authorize`, `AI consent`, `express-validator`, `central error handler`.
- **Controllers** — HTTP mapping.
- **Services** — `DPR generation`, `cluster DPR`, `OpenAI`, `quality/ML`, `financials`, `schemes`, `AP MSME`, `notifications`, `audit`, `retention`, `account erase`, `Cloudinary`, `translation`, `venture-match help`, `Whisper`.
- **Models** — `Mongoose schemas`.

On startup the main process connects to MongoDB, seeds four schemes if the collection is empty (`PMEGP`, `MUDRA`, `CGTMSE`, `MSME-CDP`), deletes any `STANDUP` scheme row, seeds `RBAC test users` if missing, pre-warms the `OpenAI assistant cache`, and schedules `retention`.

2.4 Database architecture

One MongoDB database (name is whatever `MONGODB_URI` selects; the `README` example is `msme-dpr`). Collections from models:

Model	Role
User	Account, bcrypt password hash, role, phone, DOB, privacy consent, nominee
Project	Project shell linked to the user
DPRVersion	DPR content and versions
DPRSession	Guided-builder session
DPRTemplate	Templates
DPRAnalytics	Quality and funding metrics
ClusterSection	Generated cluster sections
Scheme, SchemeMatch	Seeded scheme rows and per-project matches
SchemeDocumentStyle	Super-admin default look for a scheme code
Document, VectorStore, RAGMetrics	RAG uploads and metrics
KycFile	Encrypted identity and cluster photo metadata. Bytes live under uploads/kyc and uploads/cluster
Feedback	User feedback on a project
Policy	Admin-managed policy records
AuditEvent	Append-only audit. Application code does not update old rows
PrivacyComplaint	Grievance form submissions
UserNotification	In-app notices

There are no SQL migrations. Schema changes ship with Mongoose model edits. Indexes called out in code include unique email and analytics indexes on `projectId` and `dprId`.

2.5 API architecture and documentation

JSON over HTTP. Authenticated calls use `Authorization: Bearer <jwt>`. Success payloads use `success: true`. Errors use `success: false` and `message`. Rate limit: 100 requests per 15 minutes per IP on `/api` (override with `RATE_LIMIT_WINDOW_MS` and `RATE_LIMIT_MAX_REQUESTS`). Health check is public: `GET /api/health`.

Area	Methods and paths	Auth
Auth	POST /auth/register, /auth/login; POST /auth/logout, /auth/consent; GET/PUT /auth/profile	Register and login public. Others JWT.
Projects	POST/GET /projects; GET/PUT/DELETE /projects/:id	JWT
Schemes (DB)	GET /schemes, GET /schemes/:schemeCode, POST recommend and select	JWT
Feedback	POST /feedback, GET /feedback/:projectId	JWT
AI	POST /ai/chat, /ai/transcribe, /ai/tts, /ai/venture-match/help	JWT + AI consent
DPR core	Sessions, templates, generate, chat-generate, builder analyze/chat, get/update/delete, PDF/DOCX/XLS, quality, submit, Telugu translate	JWT. AI routes also need AI consent. Downloads do not.
Cluster / individual draft	/dpr/cluster/draft/save, generate, sections, images, financials, suggestions, annexures, /dpr/cluster/files/:fileId	JWT. Generate and AI suggestion routes need AI consent. File read is owner or admin/officer.
Scheme style	GET/PUT /dpr/scheme-style/:schemeCode	JWT. Saving a scheme default is limited to admin / super admin in schemeStyleRules.
AP MSME	GET schemes, guidelines, financial institutions; POST submit; GET status and entrepreneur	JWT
Documents / RAG	List vector stores, search, RAG query, file serve for any signed-in user. Upload, list, delete, create/delete vector stores	JWT. Mutations after authorize('admin').
Privacy	GET export, activity, notifications; PATCH consent; PUT nominee; DELETE account; POST complaint; POST notification read	JWT, own data
Admin	GET analytics, users, projects, feedback, dprs, policies, audit, audit CSV; PUT/DELETE users; approve/reject DPR; policy CRUD and approve; POST retention run	JWT + role admin

There is no published OpenAPI file. The table above is the route surface in server/src/routes.

2.6 Codebase and repository structure

AI_DRP/	
client/	React app (src/pages, components, lib, store, i18n, e2e)
server/	Express API (src/routes, controllers, services, models, middleware, lib)
server/fonts/	PDF fonts
server/scripts/	Sample DPR generators (PMEGP steel furniture, CMEP cases)
docs/	DPDP, scheme notes, business-logic markdown, this handover
vercel.json	Frontend static hosting only
README.md	Older overview; verify against code before relying on it
llm.md	Fill-this-step model behaviour
styleeditor.md	Report style behaviour
OFFLINE_DPR_GENERATION.md	

Client feature code is grouped by DPR type (individual-dpr, cluster-dpr, venture-match, dpr-builder) rather than by a single design-system package.

2.7 Data flow and application flow

1. User registers or logs in. Server returns a JWT carrying userId, email, and role. Client stores it.
2. If the notice version is not 2026-09-4, ConsentGate blocks the app until POST /api/auth/consent.
3. Scheme Finder writes progress locally, evaluates in the browser, then saves a handoff object and navigates.
4. Individual DPR loads the handoff for overlay rules only, then saves drafts with POST /api/dpr/cluster/draft/save. The URL gains projectId, dprId, and scheme.
5. Optional AI calls send a reduced facts card. The server strips identity fields, calls OpenAI, validates the JSON, and returns suggestions. Failed checks stay blank for the user to type.

6. Generate stores the report. Preview renders `IndividualDPRDocumentView`. PDF either posts captured HTML to the server or builds the Q&A document in `individualDprDocument.ts`.
7. Downloads and staff views of another user's DPR write audit rows.
8. Every six hours the API process warns or deletes idle DPRs and old audit rows, and writes in-app notifications.

2.8 Authentication architecture

- Passwords are hashed with `bcrypt` (cost 10) in a pre-save hook. The field is `passwordHash`. Minimum length 6.
- JWT is verified in `authenticate`. Secret comes from `getJwtSecret()`. Production refuses a missing secret and refuses known dummy values (`secret`, `your-secret-key`, `jwt-secret`, and the dev fallback). Development may warn and use a local dummy secret.
- Logout is an audit event. Tokens are not stored server-side, so logout does not revoke a token before it expires. Expiry is whatever `signToken` sets in the auth controller.
- AI routes use `requireAiConsent`. A false `aiAssist` flag returns 403 with code `AI_CONSENT_REQUIRED`. Draft save and downloads stay available.

2.9 Integration architecture

Outbound calls are synchronous HTTP from the request that needs them (OpenAI, AP MSME, Twilio, Cloudinary, Hugging Face). RAG upload attaches files to the OpenAI vector store id in `MAIN_VECTOR_STORE_ID`. If that variable is empty, some code paths fall through to a placeholder. Set a real store id before relying on RAG.

KYC and cluster photos stay on the API disk (optionally AES-256-GCM with `KYC_ENCRYPTION_KEY`). They are read back only through `GET /api/dpr/cluster/files/:fileId`.

2.10 Background jobs

One in-process job exists. `runRetentionJob()` starts about 20 seconds after listen, then every 6 hours, via `setInterval` in `server/src/index.ts`. An admin can also run it with `POST /api/admin/retention/run`.

There is no queue (no Bull, SQS, or cron daemon in the repo). The serverless entry does not start this timer. If more than one API instance runs `src/index.ts`, each instance will run the job. The job is written to be safe to repeat, but overlapping instances should still be treated as an operations choice, not as a designed worker fleet.

Assistant cache pre-warm at boot is a one-shot OpenAI call, not a scheduled job.

2.11 Error handling and logging architecture

Users see a short JSON message, not a log and not a stack trace, except when `NODE_ENV` is exactly `development`. In that mode the error handler also adds stack to the JSON. Production responses stay `{ success: false, message }`.

Operator logs stay on the server process:

- Morgan writes HTTP access lines to stdout (dev format).
- The error handler writes the error to stderr.
- Retention, SMS, and email helpers write their own stdout lines for operators.
- The UI uses toast text for success and failure. It does not render server logs.

Validation errors from `express-validator` return 400 with field messages. Unknown routes return 404 `Route ... not found`. Rate limiting returns a plain “too many requests” message. AI consent and under-18 refusals use stable code values (`AI_CONSENT_REQUIRED`, `UNDER_18`) so the client can show the right sentence.

2.12 Security architecture

- **Transport and headers:** Helmet, including a CSP that allows the app to frame its own PDF preview. CORS origin is `CORS_ORIGIN` or `http://localhost:5173` on the main server. Credentials are allowed. The serverless entry defaults CORS to `*`, which should not be used for a credentialed production API.
- **AuthZ:** `authorize(...roles)` plus `roleAllowed`. Admin routes and document mutations require `admin`. Scheme-style save requires `admin`. File reads allow the owner or `admin/officer`. Staff opening another user's DPR writes `admin_view`.
- **Privacy of model calls:** `sanitizeForAi` drops Aadhaar, PAN, passbook, UPI, and file-URL keys and redacts those patterns inside strings, including Cloudinary and `/uploads` URLs.

- **Files at rest:** production refuses to boot without KYC_ENCRYPTION_KEY. The key is a server secret hashed into AES-256-GCM. It is not per user. Dev may omit it; files are then private by route but plaintext on disk.
- **Public uploads:** /uploads always 404.
- **Audit:** append-only events with time, user id, role, action, optional target, and IP. Users can read their own activity. Admins can filter and export CSV.
- **Age:** registration and DPR save/generate refuse an applicant under 18.
- **Gaps already listed in 1.10:** self-selected role on register, officer write access via API, non-revocable JWT, 50 MB body limit, seeded test users.

2.13 Performance and scalability architecture

- Response compression is on.
- MongoDB pool is capped at 10 sockets. Timeouts are raised for cross-region hosts (comments mention Railway and Atlas).
- The client caches a few GET responses in memory for a few minutes.
- Fill-this-step was changed from one model call per question to at most two calls per step, specifically to cut wait time and token repeat. See `llm.md`.
- PDF capture and Puppeteer run on the API machine. That is the scaling limit for concurrent downloads. There is no horizontal worker split.
- Rate limit is in-memory (express-rate-limit default). It does not coordinate across multiple instances.
- No CDN, Redis, or read-replica configuration is in the repo. The README lines that mention them are not implemented.

3. User roles and permissions

3.1 User types and roles

The database enum is the authority for what can be stored. The UI shows different names. `client/src/lib/rbac.ts` maps them.

UI name	Stored role	Intended person
Super Admin	admin	Platform operator
Consultant	entrepreneur	Person who creates DPRs for MSME clients. This is also the default registration role.
Govt Official	officer	Reviewer of submitted DPRs and scheme alignment

Unknown or empty roles are treated as Consultant in the UI (`toAppRole`). The backend does not have a `super_admin` enum value. Tests accept both the UI name and the stored name where `roleAllowed` is given both.

3.2 Role-based access control

Two layers exist, and they are not the same.

- **API.** Most business routes require any valid JWT. Admin console and document-admin routes require stored role `admin`. Scheme default style save requires `admin`. Cluster file read and “view someone else’s DPR” treat `admin` and `officer` as staff.
- **UI.** `/admin` and `/admin/documents` require Super Admin. `canCreateDpr` is true for Consultant and Super Admin only, so Govt Official does not see create actions. Dev mode is Super Admin only. An Access Control tab on the admin dashboard previews the three roles. Its own hint text says enforcement is still UI-oriented.

3.3 User permissions

Consultant (stored `entrepreneur`), as implemented for a normal signed-in user:

- Create and edit own projects and DPRs, save drafts, generate, download PDF / DOCX / XLS.
- Use Scheme Finder, guided builder, and chat.
- Use AI features only after opting in. Typing, saving, and download still work with AI off.
- Style the current DPR. Cannot save a scheme-wide default style.
- View own quality information, profile, privacy export, activity, and notifications.
- Cannot open the admin console or upload the RAG knowledge base.

3.4 Admin permissions

Stored role `admin` (UI Super Admin), via `/api/admin` and the admin pages:

- Platform analytics.
- List users and update them, including role. An admin cannot change their own role.
- Delete a user. Deletion uses the same `eraseAccount()` path as self-service erasure.
- List projects, feedback, and DPRs. Approve or reject a DPR.
- Create, edit, delete, and approve policy records.
- Read and CSV-export the audit log. Run retention immediately.
- Upload, list, and delete RAG documents and manage vector stores.
- Save a scheme document style as the default for future DPRs.
- Open another user’s DPR (audited as `admin_view`) and read KYC/cluster files.
- Use dev mode on create-DPR screens.

3.5 Module-level access

Module	Consultant	Govt Official	Super Admin
Scheme Finder	Yes	UI does not special-case it; API allows any JWT	Yes
Create individual or cluster DPR	Yes	Hidden in UI. API still allows a valid token	Yes
Own drafts, preview, download	Yes	API allows. UI create path is hidden	Yes
Chat, guided builder, AI fill	Yes, if AI consent	Same API rule	Yes, if AI consent
Admin console	No	No	Yes
RAG document admin	No (search is allowed when signed in)	No	Yes
Scheme style default	No	No	Yes
Privacy self-service	Yes	Yes	Yes

3.6 Feature-level access

Feature	Rule
AI fill, chat, RAG query, translate, quality score, image generation, cluster narrative	AI consent required. UI disables the buttons when consent is off.
Draft save, manual typing, PDF/DOCX/XLS download	Allowed without AI consent.
Under 18 applicant	No account, no save, no generate. Scheme Finder hides create buttons when age is under 18.
Style on this DPR	Whoever can edit that DPR.
Save as scheme default	Super Admin only.
Dev mode (skip required fields)	Super Admin, create-DPR pages only, off when the page closes.
Approve / reject DPR, policies, user role change	Admin API.
Audit CSV and retention run	Admin API.
Own data export and account delete	The signed-in user. Delete requires body { confirm: "DELETE" }.

3.7 Authentication and authorization

Authentication is email + password, then JWT. Authorization is the role checks in section 3.2 plus ownership checks in DPR and file controllers (staff bypass for admin and officer). There is no per-permission table, no OAuth, no SSO, and no multi-factor authentication.

3.8 User management

- Self-service: register, login, edit profile, privacy settings, delete own account.
- Admin: user list (paged, filterable by role), edit name, email, role, location, phone, Udyam number, and delete.
- Role changes persist through `PUT /api/admin/users/:id`. The success toast text still says “Role updated in the UI”, which is misleading. The admin call is a real write.
- There is no invite email and no password-reset endpoint in the auth routes.

3.9 Access restrictions

- Under 18 cannot register or be the named applicant on a DPR.
- Account consent and the current notice version are required to pass the app gate.
- AI features refuse when `aiAssist` is false.
- Non-admins receive 403 on `/api/admin` and on document admin routes.

- KYC bytes are not on a public URL and are not sent to the model.
- Users see only their own privacy activity and notifications.

3.10 Permission workflows

1. **New consultant.** Register as Consultant. Scroll and accept the notice. Optionally enable AI. Land on the dashboard.
2. **Promote to admin or officer.** An existing admin edits the user on the User Management tab. The stored value must be admin, officer, or entrepreneur. The UI maps the three labels before sending.
3. **Review.** Admin opens DPR Management and approves or rejects. Officer is described as a reviewer in the UI copy. The approve/reject routes themselves are under the admin router, so they require stored role admin, not officer.
4. **Withdraw AI.** User turns AI off under privacy settings. Later AI calls return 403 until they opt in again.
5. **Erase.** User confirms DELETE, or an admin deletes the user. Mongo rows for that user's projects, DPRs, files, and related records are removed. Audit rows stay until the 24-month clock.

3.11 Admin and user responsibilities

Who	Responsibility
Consultant	Accurate project facts. Do not rely on AI for rupee amounts the form does not already support. Keep identity documents with the applicant for the bank or DIC. The PDF shows Uploaded or Pending for identity, not the ID number.
Govt official	Review submitted work and scheme alignment. Do not assume the UI hide is a complete write-block until the API is tightened.
Super admin	Assign roles, approve or reject DPRs, maintain policy rows and the RAG corpus, export audit when asked, run retention if a purge cannot wait for the 6-hour timer, and keep scheme default styles coherent.
Operations	Hold JWT, KYC, OpenAI, and database secrets. Rotate the seeded test accounts out of every shared database. Answer privacy complaints. Stage 4 of DPDP is still a human process: the form only stores the complaint.

4. Deployment and handover documentation

Hosting and infrastructure ownership are **not specified** for the receiving organisation. The notes below are only what this repository already contains. Fit them to the host after that choice is made.

4.1 Deployment process (as known)

Frontend. `vercel.json` installs and builds `client` and publishes `client/dist` as a single-page app. Any path is rewritten to `index.html`. Set `VITE_API_URL` at build time to the API origin.

API (manual, from the README and package scripts).

1. Node.js 18+ and a MongoDB URI.
2. `cd server && npm install`
3. Provide environment variables (section 4.2). `OPENAI_API_KEY` is required or the process exits.
4. `npm run build (tsc)` then `npm start (node dist/index.js)`. Development uses `npm run dev (ts-node-dev)`.
5. Puppeteer needs a Chrome binary. `PUPPETEER_EXECUTABLE_PATH` or `CHROME_PATH` can point at it. PDF smoke tests and HTML-capture downloads fail without it.

No Dockerfile, no docker-compose, and no CI workflow were found in the repository during this handover pass. The README's `docker-compose up` command has nothing to run.

4.2 Environment and configuration

Variable	Where	Required	Meaning
PORT	API	No (5000)	Listen port
NODE_ENV	API	Yes in production	production turns on JWT and KYC key checks and hides stacks
MONGODB_URI	API	Yes	Mongo connection string. Process exits if missing
JWT_SECRET	API	Yes in production	Strong unique value. Dummy values abort production boot
KYC_ENCRYPTION_KEY	API	Yes in production	Secret for AES-256-GCM on KYC and cluster photos
OPENAI_API_KEY	API	Yes	All AI features
MAIN_VECTOR_STORE_ID	API	For RAG	OpenAI vector store used for uploaded documents
CORS_ORIGIN	API	Yes in production	Frontend origin. Main server defaults to localhost:5173
RATE_LIMIT_WINDOW_MS	API	No	Default 900000
RATE_LIMIT_MAX_REQUESTS	API	No	Default 100
AP_MSME_API_URL	API	No	Portal base URL
AP_MSME_API_KEY	API	No	Portal bearer token
CLOUDINARY_CLOUD_NAME, API_KEY, API_SECRET	API	No	Cloudinary. All three must be set together
HUGGINGFACE_API_TOKEN	API	No	Telugu Whisper path
TWILIO_ACCOUNT_SID, TWILIO_AUTH_TOKEN, TWILIO_FROM	API	No	Real SMS. If any is missing, SMS is mocked
RETENTION_IDLE_DAYS	API	No (365)	Delete DPR this many days after its last edit. A blank value uses the default. Explicit 0 means immediately
RETENTION_WARNING_DAYS	API	No (15)	Warn this many days before that delete
AUDIT_RETENTION_DAYS	API	No (730)	Delete audit rows this old
PUPPETEER_EXECUTABLE_PATH or CHROME_PATH	API	On hosts without bundled Chrome	Browser for PDF
VITE_API_URL	Client build	Yes outside local dev	API base, including /api
VITE_USE MOCK_DATA	Client	No	true uses in-browser mock data

No `.env.example` file is in the repository even though startup text refers to one. Do not commit real `.env` files.

4.3 Hosting and infrastructure

Deferred. The receiving team will map this application onto their own infrastructure. The only hostnames present in code are Railway URLs in the API content-security policy (`ai-dpr.up.railway.app`, `dpr-server.up.railway.app`) and a Vercel config for the static client. Confirm with the current operators whether those hosts are still live before treating them as the system of record. Disk for uploads/kyc and uploads/cluster must be persistent and backed up. An ephemeral serverless disk will lose identity files.

4.4 Production setup

- `NODE_ENV=production`
- Unique `JWT_SECRET` and `KYC_ENCRYPTION_KEY`
- `CORS_ORIGIN` set to the real frontend origin, not `*`
- Run `server/src/index.ts` (the built `dist/index.js`) so retention and secret checks actually run
- Persistent disk for uploads, Chrome available to Puppeteer, MongoDB reachable within the 60-second connect window
- Remove seeded `@msme.test` users

4.5 Staging and development setup

1. Install dependencies in `server/` and `client/`.
2. Start MongoDB and set `MONGODB_URI`.
3. Set `OPENAI_API_KEY`. Other vendor keys can stay empty. SMS and email stay mocked. AP MSME scheme list falls back to mock data.
4. API: `cd server && npm run dev` → `http://localhost:5000/api`.
5. Client: `cd client && npm run dev` (Vite default port 5173).
6. Optional: `VITE_USE MOCK_DATA=true` for UI work without the API. Do not use it to test consent or auth.

First boot creates scheme rows if the collection is empty and creates three test users if those emails are absent.

4.6 Database and production configuration

- Use a dedicated database per environment. The app does not prefix collection names.
- Take a backup before the first boot against a database you care about. Boot deletes every Scheme document with code `STANDUP` and inserts the four seed schemes when the collection is empty.
- Retention defaults: DPR idle 365 days, warning 15 days before, audit 730 days. Override only with explicit integers.
- Losing `KYC_ENCRYPTION_KEY` makes existing encrypted files unreadable. Store it with the same care as the database.

4.7 Third-party account configuration

Accounts that the code can use, if the current operators already have them. None of the secrets are stored in git.

- **OpenAI** — required. Assistants, file search, and image generation are used. Fill-this-step uses `gpt-4o-mini`. Images use `dall-e-3`.
- **MongoDB** — required.
- **OpenAI vector store** — required only for RAG. Set `MAIN_VECTOR_STORE_ID`.
- **Hugging Face** — optional Telugu speech.
- **Cloudinary** — optional media.
- **Twilio** — optional SMS.
- **AP MSME ONE API key** — optional and not verified as a live contract in this repo.
- **Email provider** — not configured. No SMTP variables exist.

4.8 Backup and recovery (suggested intervals)

These intervals are a recommendation for handover. They are not implemented as jobs in the repo.

Asset	Suggested interval	Notes
MongoDB	Daily snapshot, plus point-in-time if the host supports it. Weekly copy to a second location.	Includes users, DPRs, audit, complaints
uploads/kyc and uploads/cluster	Daily, same day as the database	Useless without the encryption key from that era
KYC_ENCRYPTION_KEY, JWT_SECRET, vendor keys	On every rotation, in a password manager. Not in git.	Keep the previous KYC key until old files are re-encrypted
Source	The git remote is the copy	Confirm the remote is the one operations will keep
Restore drill	Quarterly	Restore DB + uploads + key into a scratch environment and open one DPR file

Account erasure and the 12-month DPR purge are intentional deletes. Backups are the only way to undo them, and only if policy allows restoration of personal data.

4.9 Error logs and troubleshooting

End users do not receive log files or stack traces. Support should look at the API host's stdout/stderr and at the admin audit screen.

Symptom	What to check
API will not start	Missing OPENAI_API_KEY or MONGODB_URI. In production, also JWT_SECRET and KYC_ENCRYPTION_KEY.
MongoDB errors on boot	Five retries, three seconds apart, then exit. Timeouts are 60 seconds. Confirm URI, IP allow-list, and TLS.
401 on every call	Missing bearer token, or secret mismatch after a JWT rotation (old tokens die).
403 Insufficient permissions	Route needs admin. UI Super Admin is that role.
403 with AI_CONSENT_REQUIRED	User has AI turned off. Expected.
403 with UNDER_18	Applicant age. Expected.
PDF download fails	Chrome path and Puppeteer. HTML capture also needs the 50 MB JSON limit and enough memory.
RAG answers ignore uploads	MAIN_VECTOR_STORE_ID and admin upload status.
SMS never arrives	Twilio trio unset means mock only. Check the user phone is 10 digits.
Email never arrives	Expected. Mail is not implemented.
Retention seems idle	Only the main server entry runs it. Blank env values use defaults, they do not mean zero.

4.10 Security and production access

- Production access should be limited to named operators. The app has no separate break-glass account.
- Admin is a row in users with role: admin. Create the first admin with a direct database insert or a one-off script. Do not leave self-service registration able to request admin (see section 1.10).
- Rotate JWT_SECRET only with a planned logout of all users.
- Restrict MongoDB and the upload disk to the API host.
- CSP frame exceptions for the Railway hostnames should be replaced with the real origins when hosting is chosen.

4.11 Account and credential handover

Secrets are not in git. Whoever holds the current OpenAI, MongoDB, Cloudinary, Hugging Face, Twilio, and AP MSME keys must transfer them in a password manager. This document does not contain those values.

Development users created automatically. If these emails are missing, seedRbacUsers() in server/src/index.ts inserts them on boot with a shared password that is hardcoded in that function: rbac.admin@msme.test (admin), rbac.consultant@msme.test (entrepreneur), rbac.officer@msme.test (officer). They exist so automated tests can log in. Before any shared or production database is used: delete the three users or replace the password, and stop calling the seed. The password string itself is in source control and should be treated as public.

There is no application-level handover of a root mailbox. The grievance address in the privacy notice is a placeholder until Stage 4.

4.12 Source code handover

- Git repository AI_DRP, branch feature/live_cust, commit b9be78a at the time of this document.
- Remote tracking was origin/feature/live_cust. Confirm with the current owners which remote (GitHub or otherwise) is canonical. This handover does not push or change remotes.
- License line in both packages and the README is MIT. Confirm a LICENSE file is the one the organisation intends to ship. A licence grant should be explicit in the contract, not only in a README line.
- Scheme narrative sources live under docs/schemes/ and in the client catalogs. They are product content, not a substitute for the official scheme notification

4.13 Infrastructure ownership handover

Not ready. No infrastructure-as-code, cloud account ids, or billing owners are in the repository. When the receiving team picks a host, hand over: DNS, TLS certificates, frontend host, API host, MongoDB project, upload volume, secret store, and log retention. Until then, ownership stays with whoever currently operates the Railway and Vercel targets, if those are still in use.

4.14 Admin and operations guide

1. Sign in as an admin user. Open `/admin`.
2. **Analytics** — quality and usage aggregates from `DPRAnalytics`.
3. **User Management** — search, change role, delete. Deleting a user erases their projects and files and writes an audit row.
4. **Access Control** — explanation of the three roles. It does not replace the API checks.
5. **DPR Management** — approve or reject.
6. **Policies** — draft and approve policy records stored in MongoDB.
7. **Audit log** — filter by user, action, and dates. Download CSV. Run retention.
8. **Documents** (`/admin/documents`) — upload PDF, DOC, DOCX, TXT, MD, or RTF for RAG. The README cites a 50 MB ceiling.
9. Privacy complaints are in MongoDB (`PrivacyComplaint`). Nothing emails the operator. Query that collection or add a mailbox process.

4.15 Maintenance and support guidelines

- When DPDP behaviour changes, update `docs/dpdp.md` in the same change. Notice text changes must bump `PRIVACY_NOTICE_VERSION` on server and client together (current `2026-09-4`).
- Scheme Finder rule changes belong in `docs/venture-match-business-logic.md`. Individual DPR behaviour changes belong in `docs/create-new-dpr-business-logic.md`.
- Dependencies: review OpenAI model names when the account's model access changes. `gpt-4o-mini` and `dall-e-3` are hardcoded in the paths described above.
- Support replies for privacy rights are a human queue. The product copies a grievance email and stores the form. It does not send the reply.
- Suggested support severity: API down or data loss (immediate), login or PDF failure (same day), AI quality complaint (normal), copy or translation tweak (planned).

4.16 Final project handover

What transfers with the repository today:

- Source at `feature/live_cust / b9be78a`.
- This document, plus the living docs named in the introduction.
- Automated tests listed in Part 5.
- Scheme reference notes and sample PDFs under `docs/schemes/`.

What does not transfer inside the repo and must be collected from the current operators: production URLs that are actually live, MongoDB credentials, OpenAI and other vendor accounts, the KYC encryption key, DNS, and any data-processing agreements.

4.17 Pending items at handover

1. Fix registration so a caller cannot choose admin or officer.
2. Enforce Govt Official limits on the API.
3. Remove or disable `seedRbacUsers` outside local development.
4. Pick the API endpoint and apply production guards to it.
5. Choose hosting, persistent disk, and backups. Replace Railway CSP origins if that host is retired.
6. SMTP and a real grievance inbox (DPDP Stage 4).
7. Confirm or remove the AP MSME HTTP integration.
8. Add a password-reset flow if consultants will self-serve.
9. Publish an environment template (e.g. `env.example`) without secrets.

0. Correct README claims (Redis, Docker, GDPR) so the next reader is not misled.

4.18 Post-development recommendations

- Treat Scheme Finder rules and scheme step catalogs as product content with a named owner. Official scheme text changes more often than the UI frame.
- Add a password reset and stop seeding known passwords.
- Put Puppeteer on a worker if download volume grows. Keep the API request path short.
- Gate analytics writes on `privacy.analytics` if that flag is shown to users as a real choice.
- Store test-cycle results outside chat logs (see Part 5). Git does not remember whether a suite was run.
- Run a restore drill before the first production data load.

5. Testing and QA documentation

5.1 Testing strategy

The repository uses fast, in-process tests for business rules and a few live checks that need a running API or Chrome. There is no separate QA management tool, no recorded test plan version, and no CI configuration in the repo. Strategy as it exists:

- **Unit / rule tests** for roles, scheme step catalogs, style editor behaviour, suggestion batching, cost guards, dates, under-18, AI sanitising, JWT production guard, and privacy notice version.
- **Live API tests** against a local server and the seeded consultant and admin users.
- **PDF smoke** that writes a real styled PDF when Chrome is available.
- **One Playwright flow** that logs in as the consultant, starts a bank term-loan DPR, advances a step, and names, resizes, hides, and deletes a picture.
- **Responsive audit script** (`client npm run audit:responsive`) captures screenshots. It is a tool, not an asserted test suite.
- **Sample generators** under `server/scripts/` (PMEGP steel furniture, CMEP areca and garments) produce example PDFs. They are fixtures, not a regression suite.

5.2 Test cases

Automated cases, grouped by file. Counts are the `it()` blocks in the tree at commit `b9be78a`.

File	Cases	What they lock
<code>client/src/lib/production.ui.test.ts</code>	11	Role mapping and gates. Scheme step numbering. Style presets, pictures, resize, page sizes. AP districts, technology-upgrade cap, CMEP year columns, file-id vs URL, under-18 on the form.
<code>client/src/lib/dprFixes.test.ts</code>	24	Blank answers, download filenames, scheme filters, ISO dates, cost suggestions, step batching and facts card, custom sections, live typing, style order and contrast, owner-tag rules, scheme combination exclusions.
<code>server/src/production.backend.test.ts</code>	9	Role allow/deny, scheme-style payload and route order, PDF page size and margins, under-18, AI sanitiser, JWT secret refusal, privacy notice version.
<code>server/src/api.live.test.ts</code>	3	Consultant login and bad password. Individual draft save. Admin can save a scheme default and consultant cannot.
<code>server/src/pdf.smoke.test.ts</code>	1	Styled report writes a real A3 PDF (120s timeout).
<code>client/e2e/consultant-dpr-screens.spec.ts</code>	1	Consultant login, notice re-consent if shown, create flow, picture name / resize / hide / delete.

Total automated cases in repo: 49 (48 Node tests + 1 Playwright test).

Commands:

- Client: `cd client && npm test`
- Client browser: `cd client && npm run test:screens` (needs the app and the seeded consultant)
- Server: `cd server && npm test`
- Server live API: `npm run test:api` (needs Mongo and a running API; default `http://localhost:5000/api`)
- Server PDF: `npm run test:pdf`

The root README also says `npm run test:e2e`. That script is not defined on the client or server package. The Playwright script is `test:screens`.

5.3 Functional testing

Covered automatically for: role gates, scheme step catalogs, suggestion batching, cost and date validation, owner-tag combinations, scheme mutual exclusions, draft save through the live API, and scheme-style authorisation.

Not covered by an automated case (manual when releasing): full generate for every scheme code, cluster financial statements, approve/reject, policy CRUD, account erasure, retention warning and purge, Telugu translation quality, and RAG answers after

an upload.

5.4 UI and UX testing

Playwright covers one consultant path through the style editor and picture controls. Client unit tests cover style rules (presets, order, contrast, picture width) without a browser. A responsive audit script can capture viewports. It does not fail the build. There is no visual-regression baseline in git.

Manual UI checks that matter on this branch: English/Telugu toggle, consent scroll-to-enable, Govt Official dashboard without create buttons, admin tabs, back-button labels, and mobile Scheme Finder floating controls.

5.5 API testing

`api.live.test.ts` is the only HTTP suite. It needs the seeded users and `MONGODB_URI`. It checks login, one individual draft, and scheme-style authorisation. It does not walk admin analytics, privacy export, file upload, or AI routes (those would spend model tokens and need consent flags).

5.6 Backend testing

`production.backend.test.ts` imports libraries directly (roles, scheme style, PDF page options, under-18, sanitiser, JWT secret, notice version). It does not boot Express. Controller branches (approve DPR, erase account, AP MSME fallback) are untested by this file.

5.7 Database testing

There is no dedicated database test suite, no migration test, and no fixture loader beyond the boot seeds and the live API test's draft write. Mongoose models are exercised only when `test:api` or a manual session hits a real database. Recommend a scratch database for that command so it does not write into production.

5.8 Integration testing

Integration that exists:

- Live API test: client-equivalent HTTP → API → MongoDB for login and draft save.
- PDF smoke: document service → Chrome → PDF bytes.
- Playwright: browser → UI → API, for the one consultant flow.

Not integration-tested in repo: OpenAI, Twilio, Cloudinary, Hugging Face, and AP MSME. Those paths fail or mock when keys are absent. Do not treat a green `npm test` as proof that vendor calls work.

5.9 Authentication and authorization testing

Automated:

- UI maps admin → super admin, entrepreneur → consultant, officer → govt official.
- `canCreateDpr` is false for govt official and true for consultant and super admin.
- `canAccessAdmin` is false for govt official.
- Server `roleAllowed` denies a consultant on an admin allow-list and allows super admin when that string is in the list.
- Scheme default save is allowed for super admin and legacy admin, denied for officer.
- Live test: bad password rejected. Consultant cannot save a scheme default. Admin can.
- Production JWT helper throws on a weak secret when `NODE_ENV` is production.

Not automated: registration with a forged `role`: admin, officer calling draft save, token expiry, and consent-gate UI for a stale notice version (Playwright only accepts the notice if it appears).

5.10 Notification, email, and SMS testing

No automated test calls `NotifyService`. Expected manual result with vendor keys unset: an in-app notification row, a mock SMS line on the server, and a mock email line. With Twilio keys set, SMS can be sent for a retention warning only. Email cannot be integration-tested because no mailer is implemented. Do not file an email bug for “message not received” until SMTP exists.

5.11 Cross-browser testing

Playwright is configured (`client/playwright.config.ts`, base URL `http://localhost:5173` or `E2E_BASE_URL`). The committed spec does not declare a browser matrix. No Safari, Firefox, or mobile-device results are stored in the repo. The responsive script can drive Chrome. Treat cross-browser sign-off as not yet recorded.

5.12 Security testing

Automated security-related checks are the JWT production guard, the AI field sanitiser (Aadhaar, PAN, file URLs), the under-18 refusal, and the scheme-style role check. There is no dependency-audit script in `package.json`, no ZAP/Burp baseline, and no test that registration rejects `role: admin`. That last case should be added when the registration bug is fixed. A full penetration test is not in this repository.

5.13 User acceptance testing (UAT)

No UAT script, sign-off sheet, or acceptor name is stored in git. Suggested UAT scenarios for the receiving team, derived from the product, not from a completed cycle:

1. Register a consultant, accept the notice, leave AI off, and confirm fill-with-AI is blocked while typing and download still work.
2. Complete Scheme Finder for a PMEGP-like profile and open the matching individual DPR. Confirm the form is not prefilled from the questionnaire.
3. Save a draft, leave, and resume from the dashboard.
4. Style a report (page size, section hide, picture) and confirm the PDF matches the preview.
5. Switch the preview to Telugu on one scheme that has Telugu strings.
6. Sign in as govt official and confirm create actions are absent in the UI.
7. Sign in as admin, change a role, export the audit CSV, and open document upload.
8. Export personal data and submit a privacy complaint. Confirm the complaint is stored even though no email arrives.

5.14 Regression testing

The practical regression set is:

1. `cd client && npm test`
2. `cd server && npm test`
3. When the API and database are up: `npm run test:api` and `npm run test:pdf`
4. When the UI is up: `npm run test:screens`

Run this set after changes to roles, scheme catalogs, the style editor, suggestion batching, PDF capture, or auth. Scheme content edits should also be checked against the matching file in `docs/schemes/`.

5.15 Bug and issue tracking

No issue tracker (Jira, GitHub Issues export, or similar) is vendored in the repository. Known issues for the next owner are the list in section 1.10 and the pending list in section 4.17. Fixing them should start a tracker the receiving team already uses. Do not treat this PDF as a live bug board.

5.16 Test execution history

The repository does not store test run logs, CI artifacts, dates, or pass/fail history. Git history shows feature work on individual DPR styling, suggestions, and responsive layout. It does not record that a suite was executed on a given day. Any earlier manual cycles lived outside this repo and are not recoverable from it.

5.17 Number of test cycles conducted or executed

Recorded executed cycles: none in the repository. A cycle count cannot be stated honestly from git. What can be stated is the size of the suite that exists to be executed: **49 automated cases** across 6 files, plus manual UAT that has no sign-off record here.

Recommendation: from the next release, keep a short log (date, commit, command, pass or fail, who ran it) in the team tracker. Re-run at least the client and server `npm test` commands on `b9be78a` as cycle 1 of the handover baseline, and attach the output there rather than pasting logs into user-facing screens.

Document control

Item	Value
Title	MSME AI DPR — Project Handover Documentation
Date	8 October 2026
Branch / commit	feature/live_cust / b9be78a
Method	Written from the source tree. Behaviour that is only described in README and not present in code is marked as not implemented.
Next update	When hosting is chosen, when registration role-locking lands, or when DPDP Stage 4 contacts replace the mock grievance address.